



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





Tendencias legales emergentes

Módulo 12

Tendencias legales emergentes en auditoría de ciberseguridad

Cyber Resilience Act (CRA)

- La **Reglamento (UE) 2024/2847**, aprobado en octubre de 2024 y en vigor desde noviembre de 2024, establece **requisitos obligatorios de seguridad para productos con elementos digitales**, incluyendo software y hardware conectados.
- **Obligaciones clave:** evaluación de riesgos del producto, procesos de manejo de vulnerabilidades, actualizaciones seguras y pruebas de seguridad
- **Reportes de incidentes:** fabricantes deben notificar vulnerabilidades explotadas o incidentes graves en plazos: 24h inicial, 72h detallada y reporte final en 14 o 30 días a aut
- **Impacto para auditorías:**
 - Auditorías deberán verificar que los productos usados en OT (firmware, sensores, software industrial) cumplan con CRA.
 - Se revisará evidencia de pruebas del diseño seguro, gestión de vulnerabilidades y protocolos de reporte.

Tendencias legales emergentes en auditoría de ciberseguridad

AI Act (Reglamento UE 2024/1689)

- En vigor desde agosto de 2024 (con sanciones desde febrero/agosto 2025), regula el uso de sistemas de IA dependiendo de su categoría de riesgo (mínimo, limitado, alto, inaceptable).
- Para **sistemas de IA de alto riesgo**, se exigen:
 - Robustez, precisión y seguridad frente a ataques adversariales.
 - Gestión de integridad de datos y mitigación de sesgos.
 - Documentación y trazabilidad técnica continua en todo el ciclo de vida

Relevancia en auditoría:

- Si un sistema OT incluye IA (ej. mantenimiento predictivo, optimización de procesos), las auditorías deben evaluar controles específicos del AI Act y su integración con RGPD y NIS2.
- Los informes deberán cubrir gobernanza de IA, controles técnicos y trazabilidad (data lineage, explicabilidad).

Tendencias legales emergentes en auditoría de ciberseguridad

Coherencia con marcos existentes

- Estas nuevas regulaciones se superponen con normas previas como NIS2 o DORA, reforzando temas como resiliencia, continuidad y gestión de incidentes en sectores esenciales.
- ENISA y el JRC han publicado mapas de correspondencia entre los requisitos del CRA y estándares existentes, lo que facilita su implementación con marcos como ISO o IEC

¿Qué deben auditar las organizaciones?

- **Productos digitales usados** en ambientes OT: analizar si el fabricante está obligado por CRA y si hay evidencias de cumplimiento.
- **Sistemas con IA de alto riesgo**: evaluar mecanismos de robustez, control de versión, registro de decisiones y transparencia técnica.
- **Procesos de reporte y respuesta**: comprobar si existe protocolo para vulnerabilidades de productos o fallos en sistemas IA.
- **Planes de continuidad ampliados**: incluir riesgos tecnológicos emergentes como mala función de IA o fallos de firmware crítico.

Tendencias legales emergentes en auditoría de ciberseguridad

Beneficios de incorporar estas tendencias en auditoría

- Refuerza la estrategia preventiva frente a futuras normativas del mercado.
- Mejora la resiliencia operacional más allá de la ciberseguridad tradicional.
- Posiciona a las organizaciones como líderes en cumplimiento integral, lo que puede ser una ventaja competitiva.

En resumen:

Normativa emergente	Aplicación	Implicación para auditoría OT
Cyber Resilience Act	Productos conectados/software	Verificar cumplimiento técnico y procesos de respuesta
AI Act	Sistemas IA de alto riesgo	Evaluar robustez, trazabilidad y gobernanza de IA

Estas regulaciones representan una tendencia clara hacia legislaciones **más técnicas, exigentes y multidimensionales**, donde las auditorías de ciberseguridad evolucionan de una revisión documental a una **verificación técnica del ciclo de vida de productos y sistemas inteligentes**.

Fin del curso